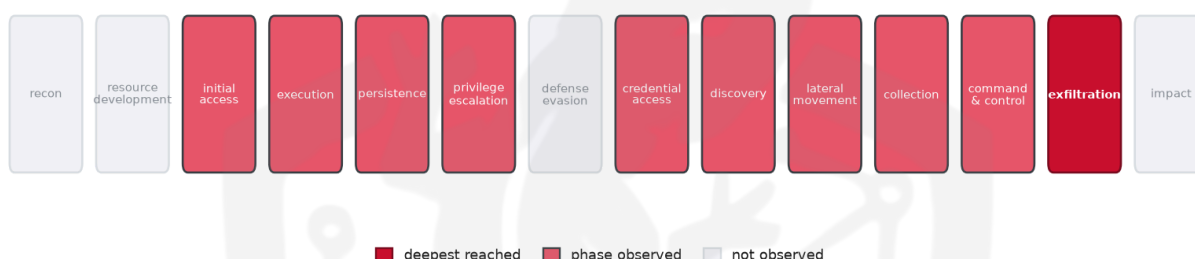


THREAT REPORT: THE GENTLEMEN DEPLOY TUKTUK C2 FRAMEWORK AND EDR NEUTRALIZATION

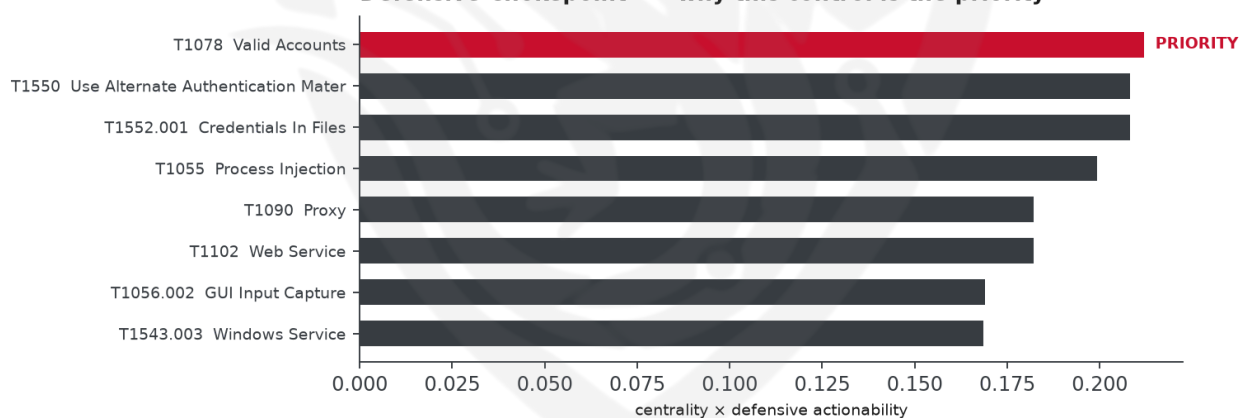
Visual Summary

Kill-Chain Reach — Critical (deepest phase reached: exfiltration)



How far down the attack chain this campaign reached; deepest phase in crimson.

Defensive Chokepoint — why this control is the priority



The control that most disrupts the attack (priority in crimson).

Summary

The Gentlemen are observed operating a suite of tools—including TukTuk, GentleKiller, EDRKiller, WarsawKiller and UnknownKiller—against organizations in the United States across defense, healthcare, technology and aerospace sectors. No specific CVE is identified in the source material. The campaign leverages a broad set of ATT&CK techniques, with a focus on abusing valid credentials to move laterally and exfiltrate data. Priority should be given to enforcing multi-factor authentication, removing dormant or over-privileged accounts, and generating alerts for impossible-travel and anomalous logons.

Threat Overview

The source attributes this activity to The Gentlemen. Their malware family includes TukTuk and several “Killer” variants. Because the central CVE is listed as Data Insufficient, no particular vulnerability is cited. Victims are U.S. entities in the defense, healthcare, technology and aerospace sectors.

Attack Chain and Priority Control

The observed chain begins with the use of stolen or legitimate credentials (T1078 Valid Accounts) to gain initial foothold, followed by system discovery (T1082, T1033), credential dumping (T1003), service creation (T1543.003), process injection (T1055), and data collection (T1005, T1213). Remote access tools (T1219) and proxy/web-service channels (T1090, T1102, T1071.001) enable command-and-control, while exfiltration proceeds over alternative protocols (T1048). The chokepoint technique is **T1078 Valid Accounts**, and the concrete control recommended is: **Enforce MFA on all accounts; disable dormant and over-privileged accounts; alert on impossible-travel and anomalous logons.**

Infrastructure and Corroboration

Enrichment data indicates no hosting providers or ASNs have been identified for the malicious infrastructure. Abuse.ch does not corroborate any of the listed malware families, and AbuseIPDB reports no indicators with confidence scores of 80 % or higher.

Technical Appendix

Ground-truth telemetry from the source pulse; analytical scores are secondary and clearly labelled.

Observed Techniques (ATT&CK, expert-tagged by source)

- T1113 Screen Capture
- T1033 System Owner/User Discovery
- T1003 OS Credential Dumping
- T1543.003 Windows Service
- T1082 System Information Discovery
- T1005 Data from Local System
- T1219 Remote Access Tools
- T1055 Process Injection
- T1550 Use Alternate Authentication Material
- T1090 Proxy
- T1102 Web Service
- T1552.001 Credentials In Files
- T1057 Process Discovery
- T1048 Exfiltration Over Alternative Protocol
- T1056.002 GUI Input Capture
- T1078 Valid Accounts
- T1068 Exploitation for Privilege Escalation
- T1213 Data from Information Repositories

- T1071.001 Web Protocols
- T1574.002 Hijack Execution Flow

Analytical Scores

- Priority technique (graph chokepoint): T1078 Valid Accounts (centrality 0.2119).
- Operational risk: Critical (score 0.968, reaches exfiltration).

Behavioral Signature Cluster

- Method: technique-overlap cosine vs 170 MITRE ATT&CK Groups (top overlap 0.3419; reference threshold $\tau = 0.6$).
- These are behavioural resemblances for defensive playbook cross-referencing, not an identity assessment. Where the source pulse names an actor, that attribution is authoritative; the overlaps below neither confirm nor contest it.

Nearest historical profiles by behavioural overlap (resemblance only):

Historical Profile	Behavioural Overlap
OilRig	0.3419
APT3	0.3195
APT32	0.3172
Ke3chang	0.3086
APT41	0.3046

Enrichment Signal

- Highest AbuseIPDB confidence among IOCs: 0%.

Indicators of Compromise (defanged — non-clickable)

The network and file indicators observed in this activity are listed below for blocklisting:

Type	Indicator
Domain	borjumaniya[.]store
Hash	4e5136230ec590ce6ef038aac6e72cb2
Hash	ba914fe77b177b45799403b16dd14765c510a074
Hash	97bd65e98cdc4e93d49edd4ea905d43a61244df0fd3323e6649330de3b1be091
Hash	138c41085f5f07adbdeff4df97a6a80252571e28

Type	Indicator
Hash	e2b31ac7ee077b26332444a83a68ab75be641113e7d86979d844a0f3478f01f9
Hash	e74088419de2e5b47b1889f2ba1369cb4b436405ce03cf07da452791681f9923
Hash	096ec37870eb401793592c9b53b5b52fc7a70b113bc2d9cd3f53231142d6c584
Hash	07f74b7d16181dec1401c85f8ebe45f3
Hash	4294c1e975d80fdedfa29919035e5efb
Hash	7c17c2bdd8d8efffb26be64245b08a22febb3cf9

Flame Cell // Adversary Pivot [BETA]

BETA. A hypothetical tabletop projection, anchored to documented ATT&CK behaviour and technique co-occurrence across 170 tracked groups. It is not a prediction; treat it as a war-game prompt and review before acting. Spot a pivot that looks wrong? norbert@salacti.com

- **Control applied:** T1078 Valid Accounts (initial-access)
- **Observed here:** T1078 Valid Accounts was the initial-access control point; blocking a means-of-entry rarely stops a determined actor, so the pivot projects forward to the execution stage they must still reach.
- **Projected pivot:** T1047 Windows Management Instrumentation (execution)
- **Basis:** of the 29+ groups that use Valid Accounts, this pairing runs 1.8x above base rate, a disproportionately-coupled move rather than the obvious one.

With T1078 Valid Accounts blocked, The Gentlemen could preserve the same objective by pivoting to T1047 Windows Management Instrumentation, a technique disproportionately paired with it across tracked groups. Defensive countermeasure: Monitor wmiprvse.exe child-process creation; restrict remote WMI (DCOM) at the host firewall; enable WMI-Activity operational logging.

Also plausible (same tactic): T1569 System Services (n=13, lift 2.0), T1053 Scheduled Task/Job (n=31, lift 1.4)

Detection and hardening for the pivot (T1047 Windows Management Instrumentation)

- **Telemetry:** Sysmon (WMI events); Microsoft-Windows-WMI-Activity/Operational
- **Detect:**
 - Sysmon 19/20/21 (WMI event filter/consumer/binding) for persistence
 - wmic.exe / WmiPrvSE.exe spawning shells; remote WMI process creation
 - WMI-Activity/Operational operations from unusual users/hosts
- **Harden:**
 - Restrict WMI remote access; monitor permanent WMI subscriptions
 - Least-privilege; segment management protocols

- **MITRE:** M1040 Behavior Prevention, M1038 Execution Prevention, M1026 Privileged Account Management · DS0009 Process, DS0005 WMI, DS0017 Command

